

INTRODUCTION AU TEST D'INTRUSION

Lettre de mission

TP 1 · Lire une lettre de mission



1 Identification de la mission

- ◆ Client : Coopérative Sahel-Vert
- ◆ Prestataire : Cabinet Harmattan
- ◆ Objet : cadrage d'un test externe à faible impact
- ◆ Début des activités autorisées : 2026-06-03
- ◆ Fin des activités autorisées : 2026-06-19
- ◆ Langue de travail : français
- ◆ Livrables attendus : journal de mission et note de cadrage

2 Cadre légal et déontologie

- ◆ Toute action doit rester dans le périmètre explicitement écrit ci-dessous.
- ◆ Aucun acte ne vaut accord implicite pour un partenaire ou un sous-traitant.
- ◆ La mission vise à vérifier l'exposition et à prioriser des suites défensives.
- ◆ Les preuves doivent rester minimales et liées à l'objectif de cadrage.
- ◆ Toute donnée sensible observée doit être signalée comme sensible et minimisée.
- ◆ Aucune loi réelle n'est citée dans ce document ; les règles viennent du présent mandat fictif.

3 Objectifs assignés

- ◆ Vérifier que l'équipe lit correctement la lettre avant toute action.
- ◆ Distinguer les cibles nettement confiées des cibles voisines ou tierces.
- ◆ Distinguer les actions directement autorisées des actions bloquées ou à clarifier.
- ◆ Confirmer la fenêtre quotidienne et les contacts d'escalade.
- ◆ Identifier les actifs qui exigent un compte de test avant toute action authentifiée.

4 Périmètre explicitement confié

- ◆ Noms de domaine et services confiés :
- ◆ sahel-vert.example
- ◆ www.sahel-vert.example
- ◆ portail.sahel-vert.example
- ◆ mail.sahel-vert.example
- ◆ vpn.sahel-vert.example
- ◆ paie.sahel-vert.example
- ◆ stock.sahel-vert.example
- ◆ Bloc public autorisé pour les scans légers : 198.51.100.0/24
- ◆ Segment public complémentaire autorisé seulement en revue documentaire : aucun
- ◆ Les cibles internes ne font pas partie de ce cadrage externe.

5 Cibles hors périmètre par principe

- ◆ Toute cible partenaire ou fournisseur non signée par le client.
- ◆ Toute cible RH externe ou portail social distinct du client.
- ◆ Toute plage interne du client non exposée publiquement.
- ◆ Tout domaine comportant une faute de frappe ou un ancien suffixe.
- ◆ Tout sous-domaine non cité dans la présente lettre reste à confirmer avant action.

6 Comptes de test fournis au départ

- ◆ Le client a livré uniquement les comptes suivants :
- ◆ portail.sahel-vert.example → portail-audit
- ◆ stock.sahel-vert.example → stock-audit
- ◆ Aucun compte n'est livré au départ pour le VPN.
- ◆ Aucun compte n'est livré au départ pour l'application de paie.
- ◆ Sans compte livré, le testeur s'arrête à la lecture passive et à la demande formelle.

7 Données sensibles et preuves

- ◆ Les preuves sur la paie restent minimales et doivent être validées avant extraction.
- ◆ Les données personnelles ne sortent pas du cadre convenu sans validation écrite.
- ◆ Une preuve minimale vaut mieux qu'une copie complète d'écran ou de table.
- ◆ Les identifiants observés sont traités comme des données sensibles de mission.

8 Contacts autorisés

- ◆ Cheffe de mission côté prestataire : Mariam Diallo
- ◆ Testeur en charge du pré-cadrage : Yao Kouassi
- ◆ Contact technique d'urgence : Ibrahim Sanou - directeur informatique du client
- ◆ Contact juridique pour toute question de légitimité ou de données : Rokia Bamba - responsable juridique du client

9 Règles de décision à appliquer

- ◆ Un nom exactement listé et porté par le bon bloc public entre en périmètre.
- ◆ Un nom exact résolu hors des blocs autorisés sort du périmètre pour raison réseau.
- ◆ Un sous-domaine de sahel-vert.example non écrit ici ne devient pas autorisé par simple proximité.
- ◆ Une action passive sur une cible hors périmètre reste hors périmètre.
- ◆ Une action sur une bonne cible peut rester interdite par les règles d'engagement.

10 Livrables et clôture

- ◆ Le cadrage attendu tient sur une note claire avant toute action technique.
- ◆ Les propositions doivent être classées en périmètre, interdit ou à clarifier.
- ◆ Toute ambiguïté doit citer la phrase de la lettre ou des règles qui manque.
- ◆ La mission se termine par un rappel des conditions d'arrêt et des comptes manquants.

11 Rappel final

- ◆ Sans accord écrit explicite, une cible ou une action n'est pas ajoutée par déduction.
- ◆ Lis cette lettre avant de lire la liste des cibles et des actions proposées.
- ◆ Les règles d'engagement complètent cette lettre et peuvent interdire une action autrement plausible.



Pingo veille sur ta progression

Retourne au laboratoire pour valider tes réponses. Bloqué ? Ouvre d'abord l'indice de la tâche, la correction vient ensuite.